



Context Matters: Repository-Aware Security Analysis of the Agent Skill Ecosystem

Florian Holzbauer, David Schmidt, Gabriel
Gegenhuber, Sebastian Schrittwieser and
Johanna Ullrich

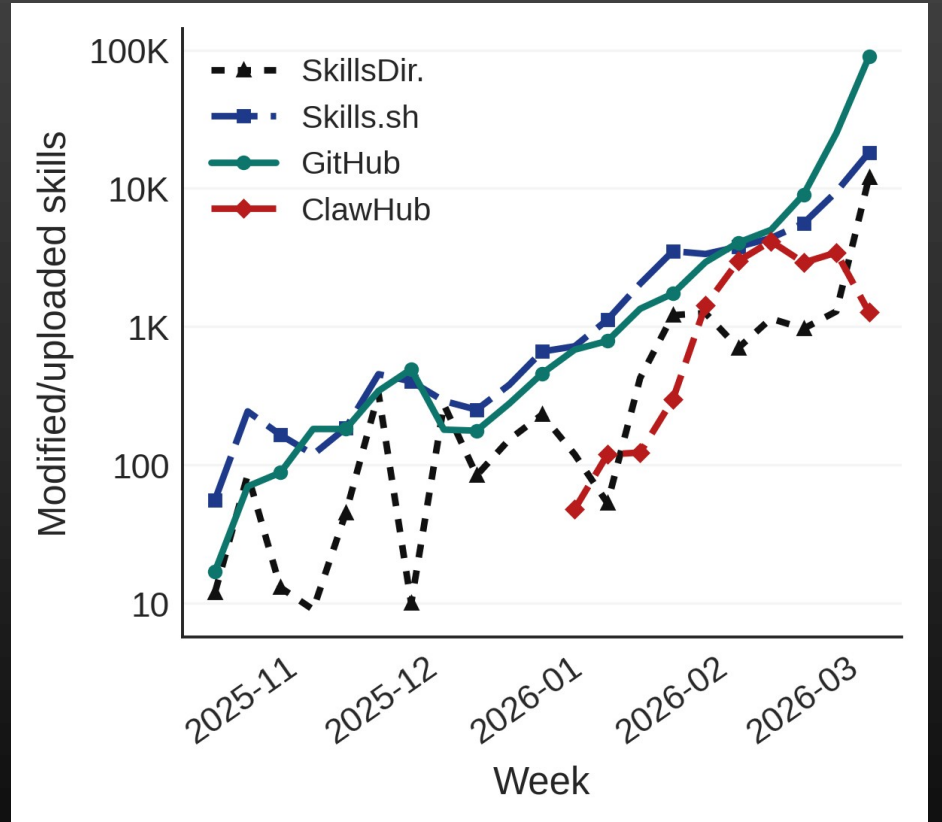


interdisciplinary
transformation
university austria

Motivation



Agent skill sharing is rapidly gaining momentum.



Motivation



Agent skill sharing is rapidly gaining momentum.



Abuse by malicious actors. High malicious rates of skill scanners. Trust in shared skills?

341 malicious skills turned ClawHub into a malware bazaar

February 17, 2026 · 22 min read



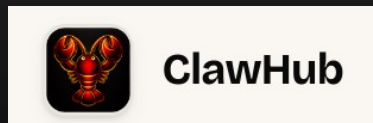
Dhayabaran V
Barrack AI

The Agent Skill Ecosystem

March 9, 2026

Clawhub.ai

- 18K Skills
- 46.8% flagged suspicious



Skills.sh

- 87K Skills
- 23% flagged



Skills Directory.com

- 36K Skills
- 6% flagged



Motivation



Agent skill sharing is rapidly gaining momentum.



Abuse by malicious actors. High malicious rates of skill scanners. Trust in shared skills?



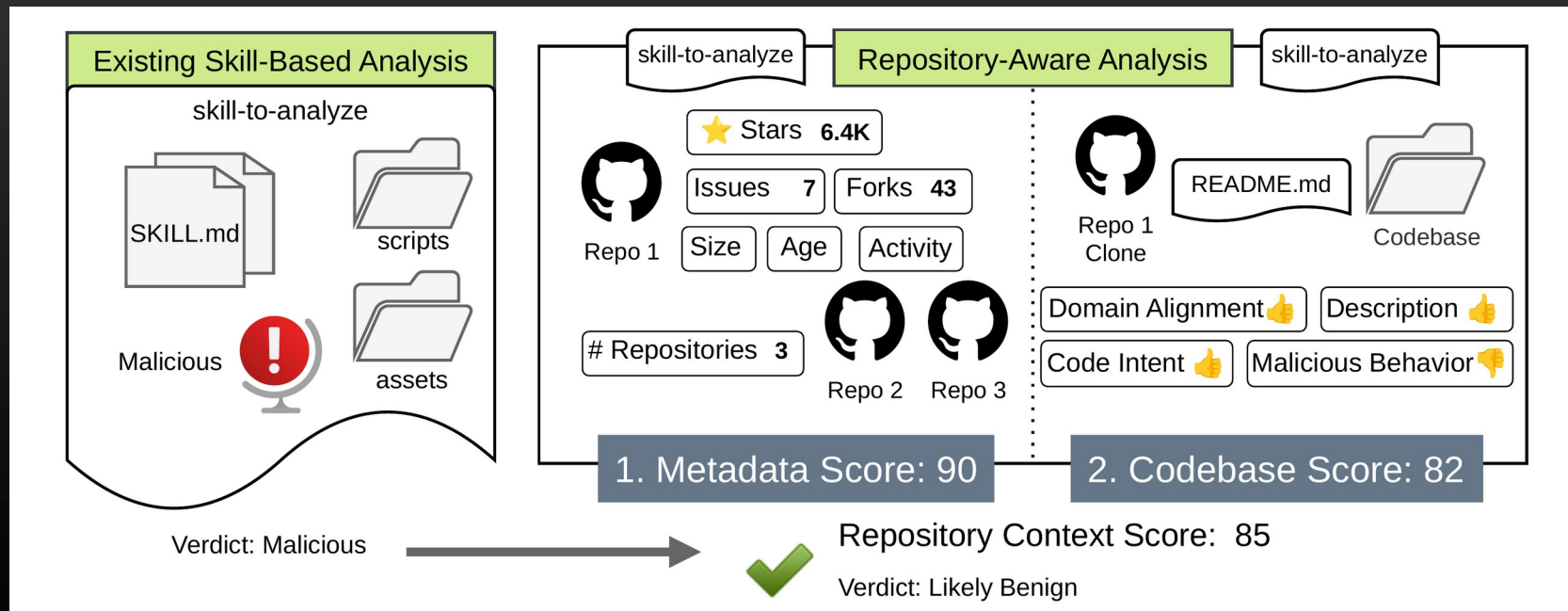
Analyze **repository context** to improve classification and provide additional trust metric.

Methodology

1. Cross Platform Skill Dataset

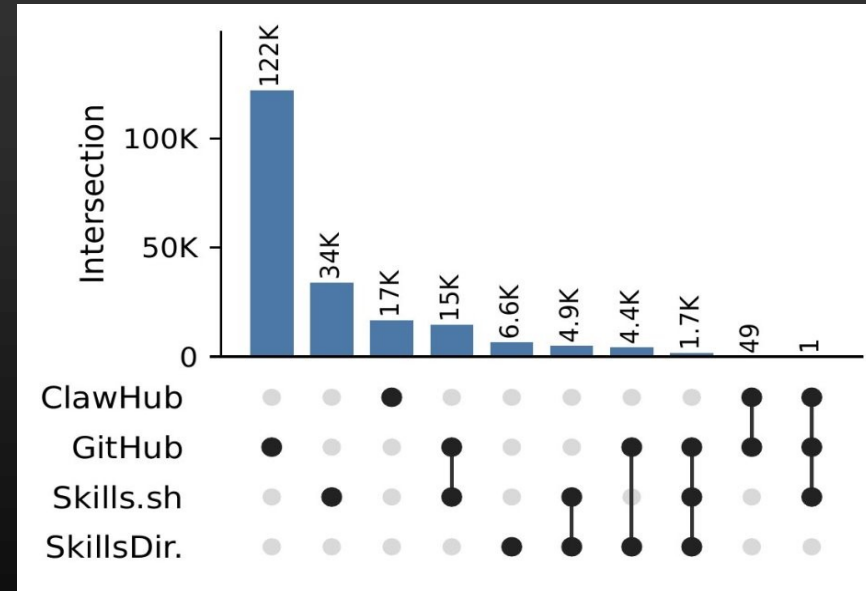
2. Skill-scanner Classification

3. Repository-Aware Analysis



Results: Cross-Platform Skill Dataset

- 238,180K collected skills



Results: Cross-Platform Skill Dataset

- **Repository Context:**
available for 93% of collected skills
- **Skill Provisioning:**
Clawhub direct
Others through Github
- **Supply Chain Attack:** Skills with 1K+ installs hijacked

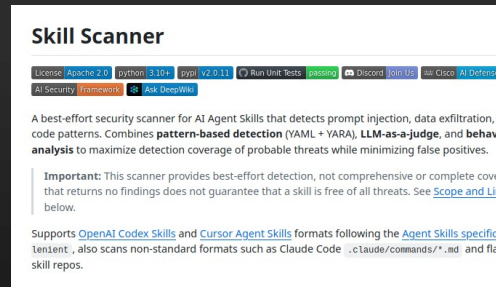


Results: Skill Scanner Classification

- Effect of scanner on flagging rate:
3.8% Snyk

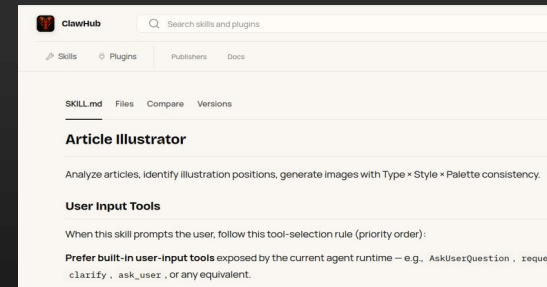


14-16% Cisco



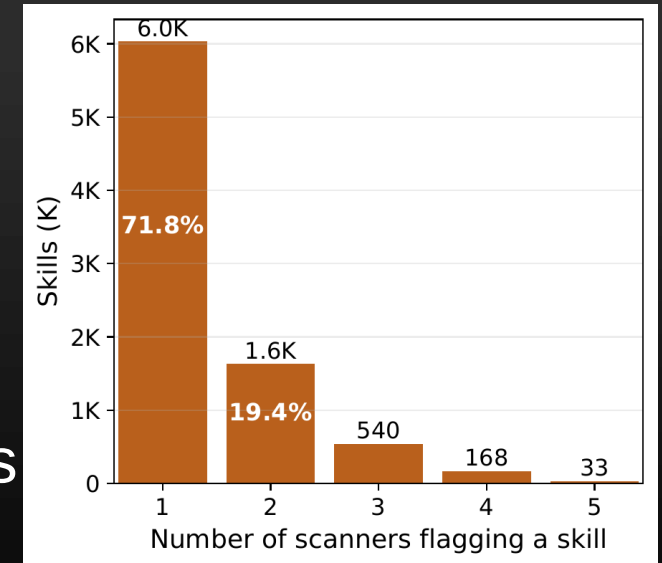
(Static + Behavior)

42% OpenClaw



(LLM-Judge)

- Scanner consensus limited: only 33 out of 8,402 skills (0.4%) are flagged by all five indexed scanners.



Results: Repository Context

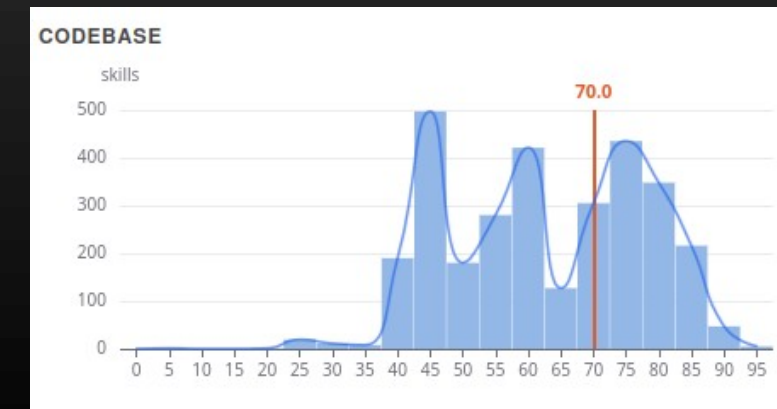
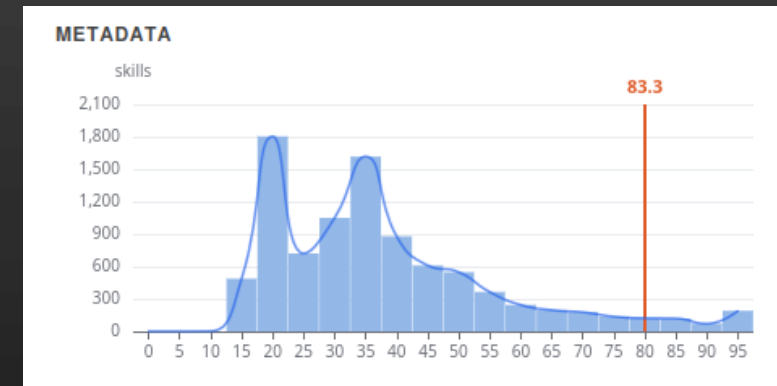
■ Metadata Score: Static

- ★ 43% of new skill repos have 0 stars
- ⌚ 73% are 1 month to 1 year old

■ Codebase Score: LLM-Judge

- ↺ Domain alignment (72%), README (69%), and codebase (39%).
- 😈 only 2% show repository-level maliciousness signs.
 - 0.52% not related to security tooling.

alibaba/higress



Conclusion

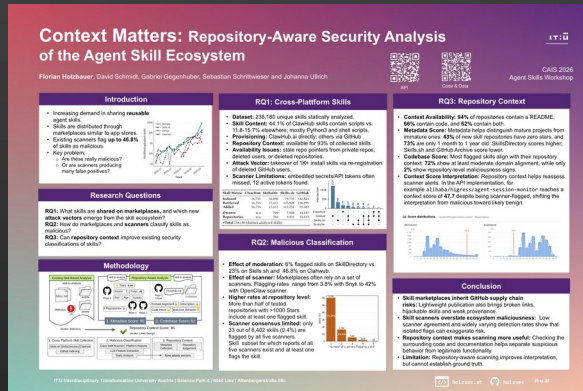
 Skill marketplaces
inherit supply-chain
risks

 Repository context:
Codebase alignment and
metadata score can assist
security analysis

 Skill scanners
currently overstate risk

 Repository-aware
scanning is not ground
truth

Poster



Code & Data

repository-context-
agentskills



Contact



holzsec



holzsec.at

Frontend

agentskills.intern
etwarte.eu

